

Der Equifax-Datenleck

Im September 2017 gab Equifax ein massives Datenleck bekannt, von der über 145 Millionen US-Verbraucher betroffen waren. Zu diesem Zeitpunkt war Equifax eine der führenden Kreditauskunfteien. Die Angreifer, vier chinesische Cracker, die in Verbindung zum chinesischen Militär gebracht wurden, nutzten eine Software-Schwachstelle (CVE-2017-5638) im automatischen System zur automatisierten Bearbeitung von Verbrauchieranfragen (Automated Consumer Interview System, ACIS) von Equifax aus, die nicht gepatcht war. Probleme bei der Systemwartung, fehlende rechtzeitige Updates, mangelnde Netzwerksegmentierung zwischen den Systemen und Datenbanken sowie fehlende Systeme zur Überwachung der Datenintegrität.

Das GTVM-Team, Eine Gruppe, die für die Sicherheit von Third-Party-Software zuständig ist, von Equifax informierte über 400 Mitarbeiter über eine schwerwiegende Schwachstelle (CVE-2017-5638) und scannte sie mit dem McAfee Vulnerability Manager, der im Oktober 2015 als "End-of-Life" angekündigt wurde. Dies bedeutete, dass keine neuen Funktionen hinzugefügt werden würden, sondern nur grundlegende Updates. Trotzdem setzte Equifax im März 2017 immer noch auf diesen Manager, was auf Probleme in deren Sicherheitssystemen hinwies.

Bei Apache Struts gab es schwerwiegende Sicherheitsprobleme, die es Angreifern ermöglichten, ihre eigenen Befehle auszuführen. Die Sicherheitslücke, die in der von Equifax verwendeten third-party Software Apache Struts gefunden wurde, wurde am 7. März 2017 mit einem Patch öffentlich bekannt gegeben, aber von Equifax nicht rechtzeitig gepatcht. Diese Sicherheitslücke CVE-2017-5638 wurde vom Common Vulnerability Scoring System als "most critical", also als "äußerst kritisch" eingestuft [DE21, S.75-95].

Im Normalfall würde man ein Angreifermodell aufstellen, bevor ein System angegriffen wird, um einen angemessenen Schutzmechanismus aufzustellen. Zur Übungszwecken sollt ihr verkehrt rum nach den Angriffen die Angreifer analysieren und folgende Fragen beantworten:

- Welche grundlegende Schutzziele wurden verletzt und warum?
- Welche Rolle hatten die Angreifer?
- Wie konnten sich die Angreifer verbreiten?
- Welches Verhalten hatten die Angreifer?
- Welche Recourcen und Kompetenzen hatten die Angreifer?
- Welche Motivation hatten die Angreifer?